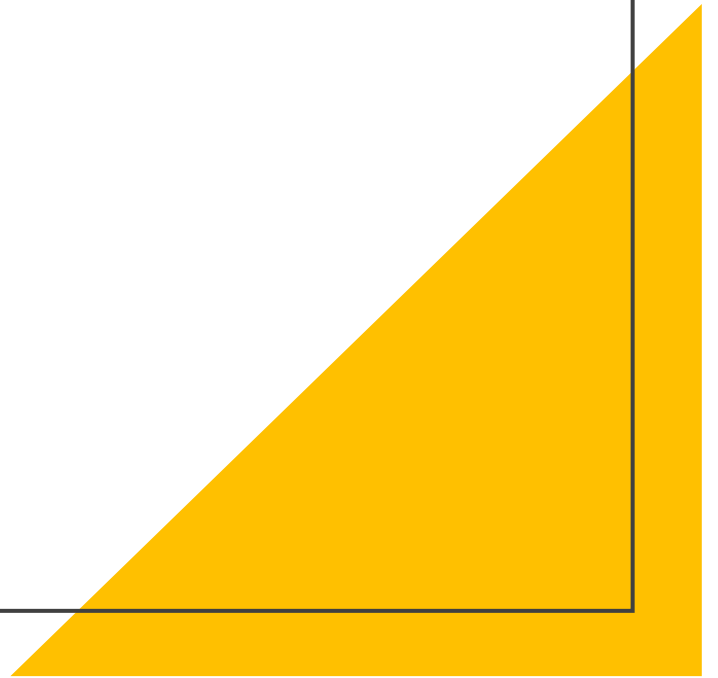


Sociotechnical Security

CS 8803/4803

Professor Veronica Rivera

Lecture 7 – Phishing and Social Engineering



Last time

1. Solution approaches to weak/shared password problems
 1. Password policies
 2. Password meters
 3. Other forms of authentication
 1. Password managers
 2. 2FA (TOTP)
 3. Hardware tokens (key-based)
 4. Biometrics
 5. Passkeys

Today

1. Problem: people handing over their credentials to attackers (phishing)
2. Phishing solution approaches

Recap of first paper

Why Phishing Works

Rachna Dhamija
rachna@deas.harvard.edu
Harvard University

J. D. Tygar
tygar@berkeley.edu
UC Berkeley

Marti Hearst
hearst@simms.berkeley.edu
UC Berkeley

ABSTRACT

To build systems shielding users from fraudulent (or *phishing*) websites, designers need to know which attack strategies work and why. This paper provides the first empirical evidence about which malicious strategies are successful at deceiving general users. We first analyzed a large set of captured phishing attacks and developed a set of hypotheses about why these strategies might work. We then assessed these hypotheses with a usability study in which 22 participants were shown 20 web sites and asked to determine which ones were fraudulent. We found that 23% of the participants did not look at browser-based cues such as the address bar, status bar and the security indicators, leading to incorrect choices 40% of the time. We also found that some visual deception attacks can fool even the most sophisticated users. These results illustrate that standard security indicators are not effective for a substantial fraction of users, and suggest that alternative approaches are needed.

INTRODUCTION

What makes a web site credible? This question has been addressed extensively by researchers in computer-human interaction. This paper examines a twist on this question: what makes a *bogus* website credible? In the last two years, Internet users have seen the rapid expansion of a scourge on the Internet: *phishing*, the practice of directing users to fraudulent web sites. This question raises fascinating questions for user interface designers, because both phishers and anti-phishers do battle in user interface space. Successful phishers must not only present a high-credibility web presence to their victims; they must create a presence that is so impressive that it causes the victim to fail to recognize security measures installed in web browsers.

Data suggest that some phishing attacks have convinced up to 5% of their recipients to provide sensitive information to spoofed websites [21]. About two million users gave information to spoofed websites resulting in direct

Types of Phishing: Spear Phishing

- A targeted phishing attack: the attacker gathers context about the victim (name, position, employer) before striking.

RESEARCH INTERNSHIP OPPORTUNITY

Dear Student,

The Office of Career Services is pleased to share an exciting professional development opportunity with current students and recent alumni of the university.

In collaboration with the Department of Computer science, we are offering a fully remote, paid research internship under the supervision of **Professor James Landay**

. This program is designed to provide meaningful, hands-on experience in research while allowing flexibility to accommodate academic and personal schedules.

Internship Overview

- Compensation: \$350 per week
- Location: Remote (participate from anywhere)
- Schedule: Flexible hours

How to Apply

Email Professor James Landay at jameslanday09@gmail.com with the following information:

- Full Name
- University Student Email Address
- Alternate Email (if applicable)
- Phone Number
- Academic Department
- Year of Study or Graduation

Applications will be reviewed on a rolling basis, with preference given to early submissions.

If you have any questions, please Email Professor James Landay using the Email above.

We encourage you to apply and take advantage of this opportunity to build your skills, enhance resume, and connect with professionals in the field.

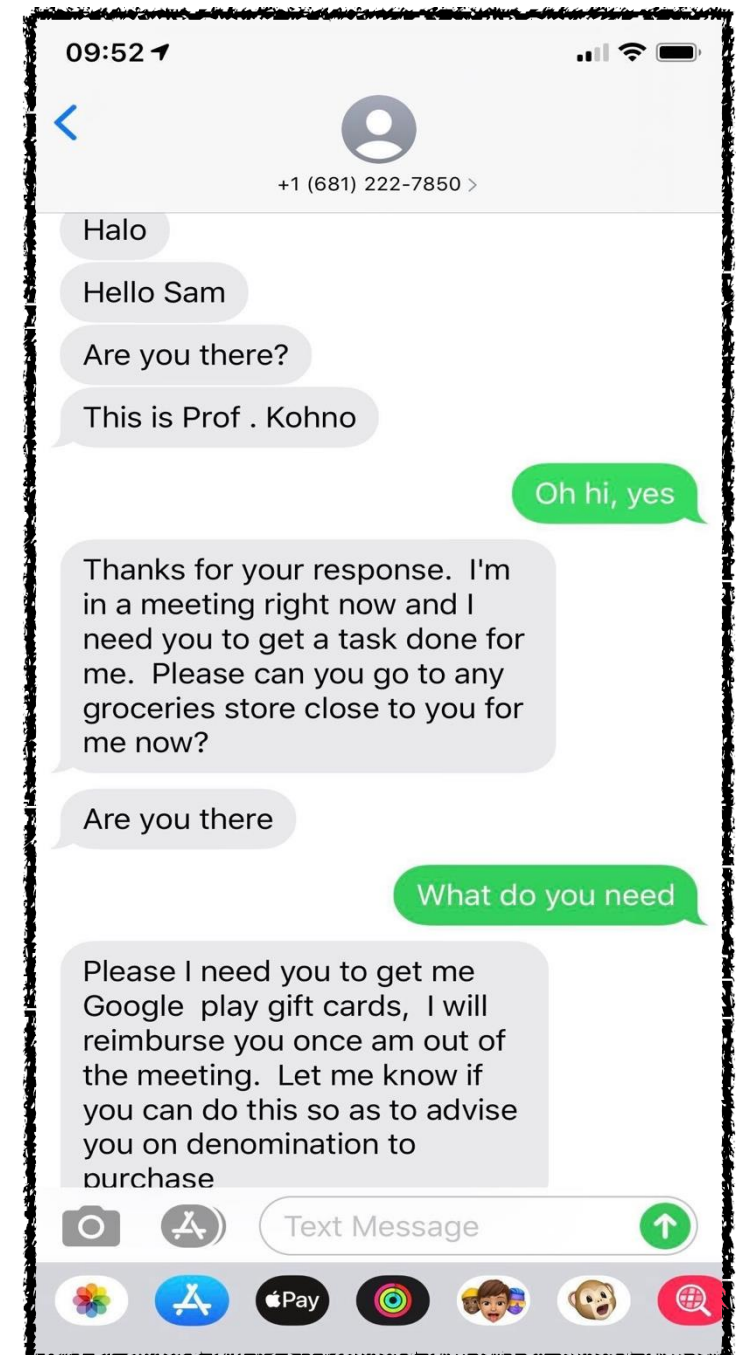
Sincerely,

Professor James Landay

Stanford University
450 Jane Stanford Way, Stanford, CA 94305

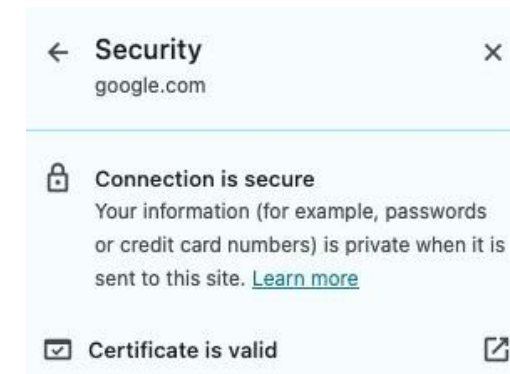
Types of Phishing: Smishing

- Phishing delivered over SMS or other text messaging, often impersonating someone the victim knows.



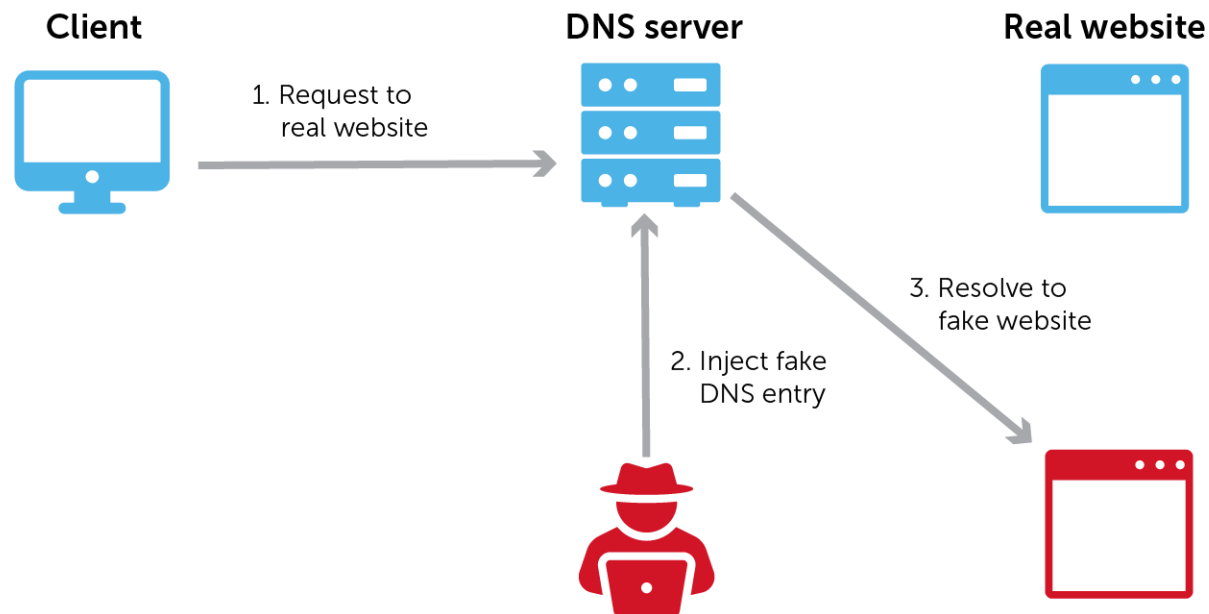
Types of Phishing: HTTPS Phishing

- The attacker lures the victim to a convincing fake website — often with a valid certificate — and harvests whatever they enter.



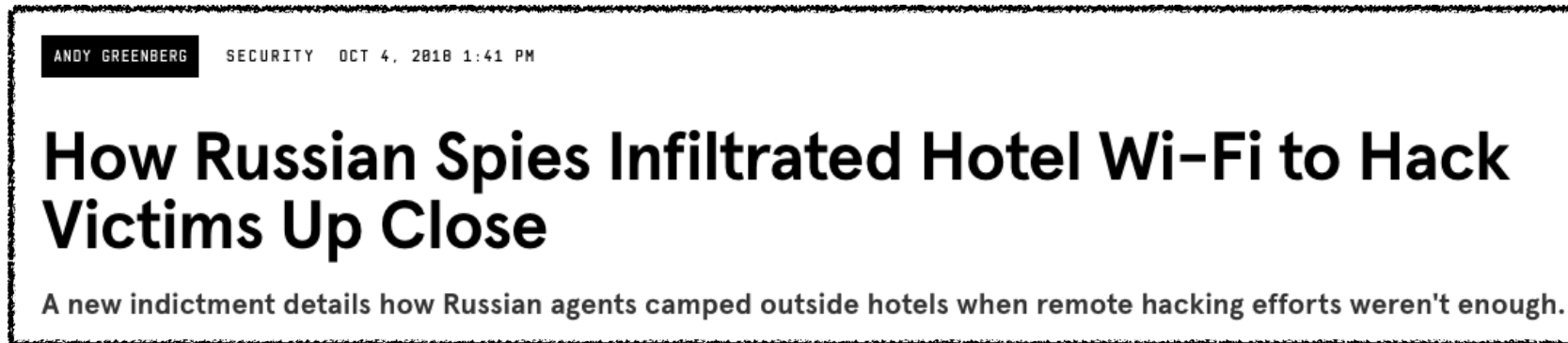
Types of Phishing: Pharming

- Hijacking DNS or browser settings so a legitimate URL request is silently redirected to a fake website.



Types of Phishing: Evil-Twin Phishing

- The attacker runs a fake Wi-Fi access point; anyone who connects has their traffic monitored.



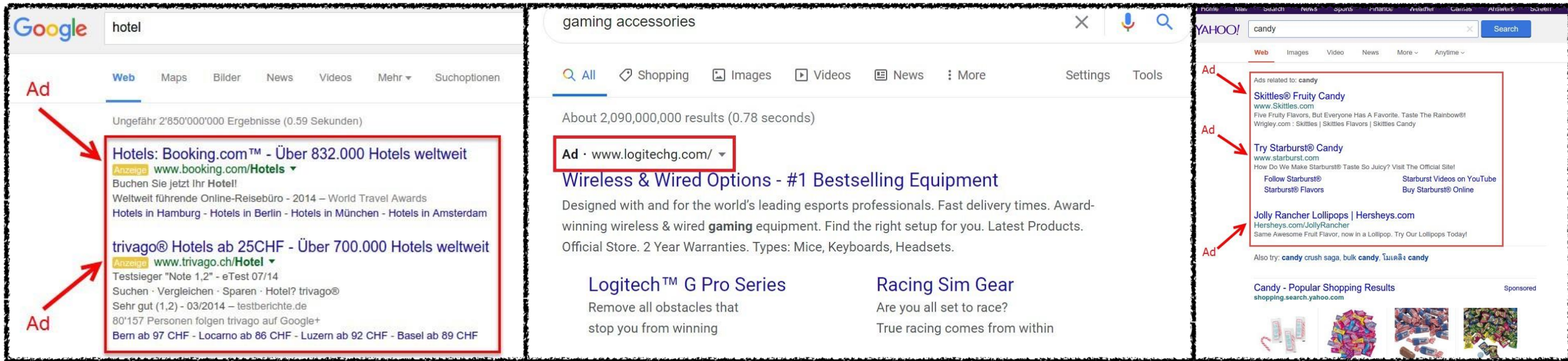
Types of Phishing: Angler Phishing

- Attackers create fake social media accounts for real organizations and interact with users as if they were customer support.



Types of Phishing: Search Engine Phishing

- Attackers buy ads on popular search engines; the ads send victims to fake websites.



Types of Phishing: Vishing

- Vishing is short for “voice phishing”: using a phone call to deceive the target into handing over information.



Susceptibility to Voice Phishing

- People are more susceptible to vishing with US-English voice prompts than with prompts in their own native-language accents.
- Ray et al., “Exploring the Impact of Ethnicity on Susceptibility to Voice Phishing,” SOUPS 2023

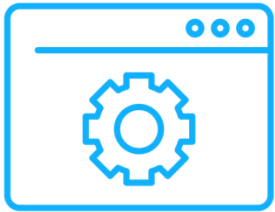
Exploring the Impact of Ethnicity on Susceptibility to Voice Phishing

Aritra Ray*, Sohini Saha*, Krishnendu Chakrabarty[†], Leslie Collins*, Kyle Lafata*, Pardis Emami-Naeini*

**Duke University*

[†]Arizona State University

Anti-Phishing Strategies



Anti-phishing
tools/software



User education

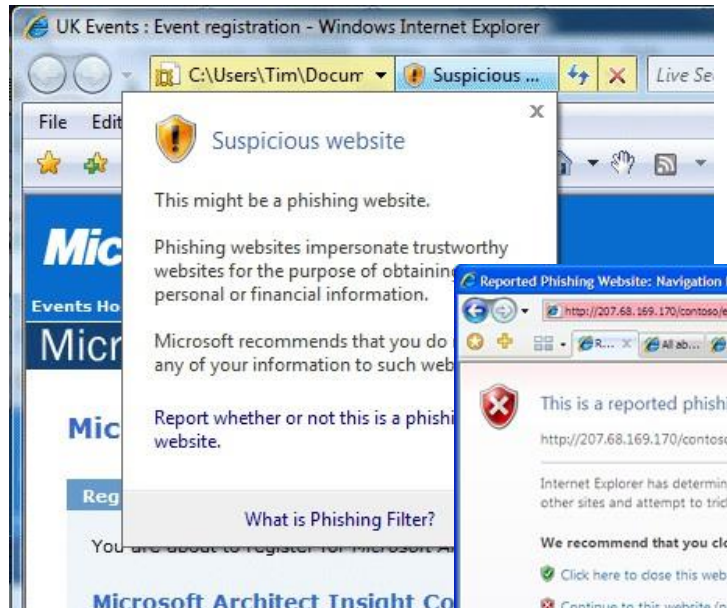


Reporting attacks

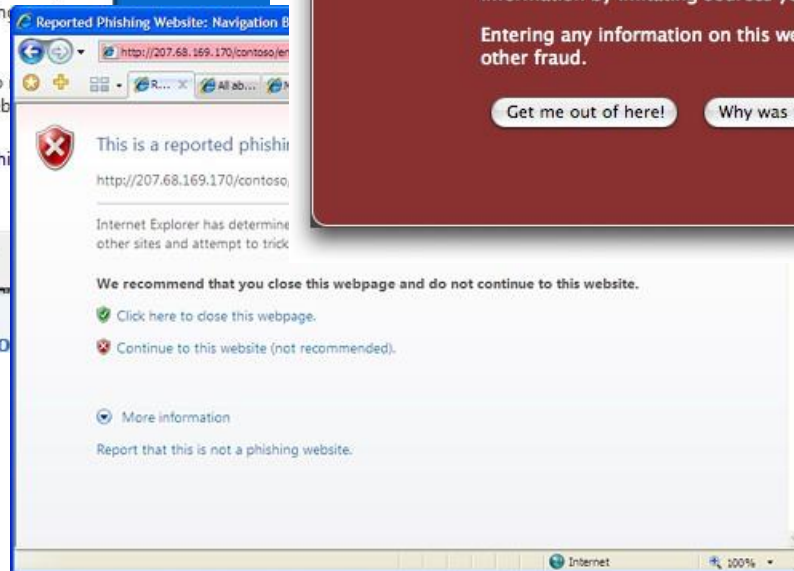
Anti-Phishing Tools and Software

- **Detection and notifications:**
 - Websites: anti-phishing toolbars (e.g., Microsoft, NetCraft, Google/Firefox, AOL, EarthLink, eBay, Geotrust, Netscape, McAfee)
 - Emails (e.g., Avanan, Valimail)
- **Security warnings:** interface elements that inform people of a webpage's security properties, either blocking or non-blocking

Phishing Warnings (2008)



Passive (IE)



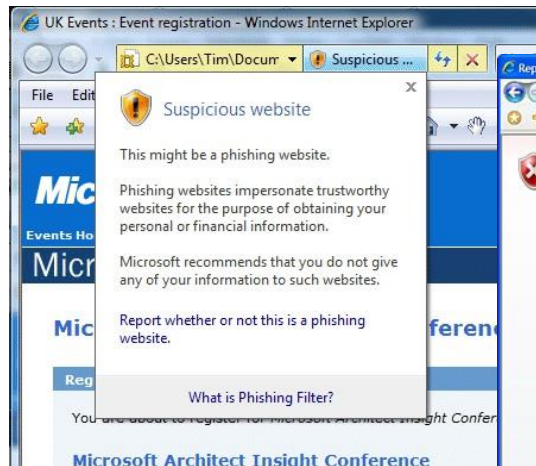
Active (IE)



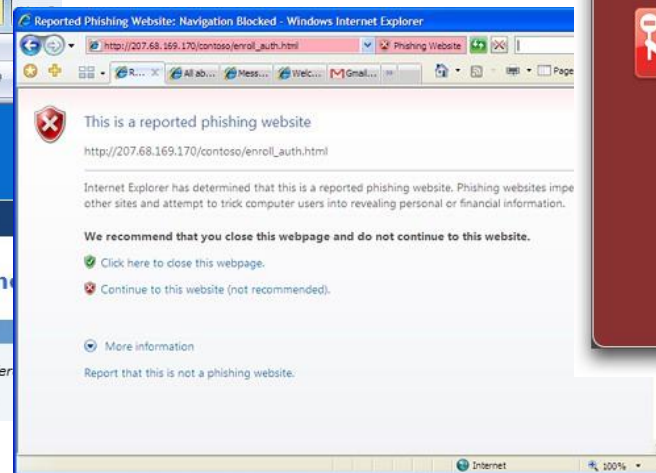
Active (Firefox)

Active vs. Passive Warnings

- Active warnings significantly more effective
 - Passive (IE): 100% clicked, 90% phished
 - Active (IE): 95% clicked, 45% phished
 - Active (Firefox): 100% clicked, 0% phished



Passive (IE)



Active (IE)



Active (Firefox)

Another Idea: Site Authentication Image

Bank of America | Online Banking | SiteKey | Verify SiteKey - Windows Internet Explorer

https://sitekey.bankofamerica.com/sas/signonSetup.do

Bank of America | Online Banking | ...

Bank of America Higher Standards Online Banking

Confirm that your SiteKey is correct

If you recognize your SiteKey, you'll know for sure that you are at the valid Bank of America site. Confirming your SiteKey is also how you'll know that it's safe to enter your Passcode and click the **Sign In** button.

An asterisk (*) indicates a required field.

Your SiteKey:
pelicans



If you don't recognize your personalized SiteKey, don't enter your Passcode.

* Passcode:
(4 - 20 Characters, case sensitive)

Sign In

If you don't recognize your personalized "SiteKey", don't enter your Passcode

Recap of second paper

Who Provides Phishing Training? Facts, Stories, and People Like Me

Rick Wash
Michigan State University
East Lansing, MI
wash@msu.edu

Molly M. Cooper
Michigan State University and
Nova Southeastern University
East Lansing, MI
mmcooper@msu.edu

ABSTRACT

Humans represent one of the most persistent vulnerabilities in many computing systems. Since human users are independent agents who make their own choices, closing these vulnerabilities means persuading users to make different choices. Focusing on one specific human choice – clicking on a link in a phishing email – we conducted an experiment to identify better ways to train users to make more secure decisions. We compared traditional facts-and-advice training against training that uses a simple story to convey the same lessons. We found a surprising interaction effect: facts-and-advice training works better than not training users, but only when presented by a security expert. Stories don't work quite as well as facts-and-advice, but work much better when told by a peer. This suggests that the perceived origin of training materials can have a surprisingly large effect on security outcomes.

ACM Classification Keywords

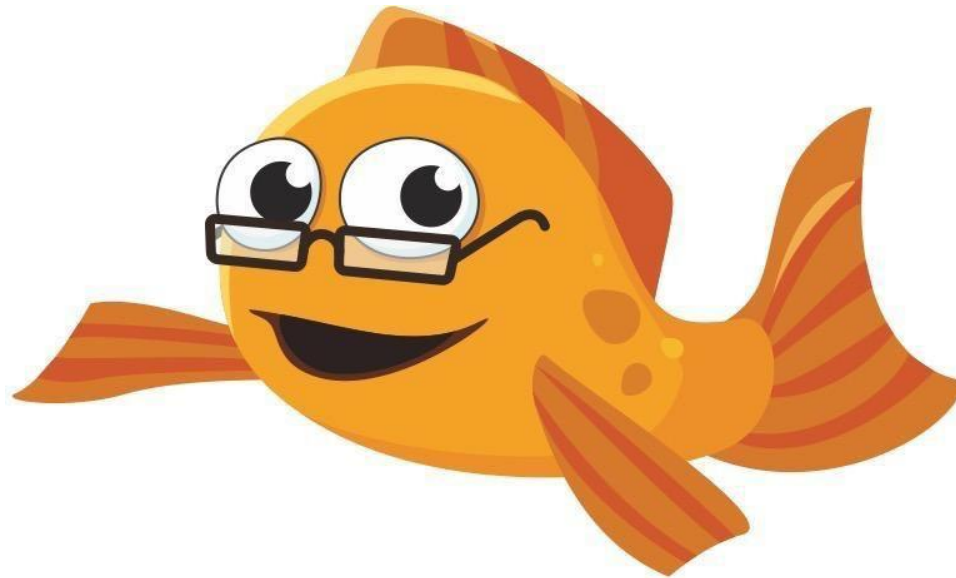
K.6.5. Security and Protection: Miscellaneous

interfaces with a human largely has no purpose. Humans are integral parts of modern computing systems: they provide inputs and read outputs of the system; they design, build, program, and configure the systems to work on their behalf; and they make a variety of critical decisions that the computers are unable to make themselves. In these roles, humans function as a critical component of modern computing systems, and as such, they can also create vulnerabilities in the system. For example, they may choose to click on inappropriate links in email messages they receive that install malicious software, or choose to disclose sensitive information on an inappropriate webpage (both of which go under the name “phishing”).

However, unlike computers, humans cannot be programmed to perform. They cannot easily be patched to change their behavior when a vulnerability is discovered. And they do not behave deterministically, so even if they behave correctly today, they might make a different decision tomorrow. “Patching vulnerabilities” in the human users of systems is one of the most challenging aspects of computer security. Since humans

PhishGuru

- Embedded anti-phishing training delivered at the moment someone falls for a simulated phish.



[School of Phish: A Real-World Evaluation of Anti-Phishing Training](#), Kumaraguru et al., SOUPS 2009



WARNING!

Clicking on links like the one in the email you at risk for identity theft. A phishing email and web pages to steal bank account passwords, and other confidential information.

PhishGuru Embedded Training

How you were tricked

This email is from my bank and it is asking me to update my information. I better click on the link and update it.

STOP!

Don't fall for this scam email.

Wombank

From: service@Wombank.com

Dear Jane,
Your account will be suspended if you do not update your information.
<http://www.Wombank.com/update>

How to help protect yourself

1 Don't trust links in an email.

<http://www.amazon.com/update>

2 Never give out personal information upon email request.

Name: Jane Smith

SSN: 123 456 789

3 Look carefully at the web address.

<http://www.amazon.com>

4 Type in the real website address into a web browser.

<http://www.amazon.com>

How phishers trick you

Here is how con artists try to steal your personal information.

Wombank

From: service@Wombank.com

Dear Jane,
Your account will be suspended if you do not update your information.
<http://www.Wombank.com/update>

I forged the address to look genuine.

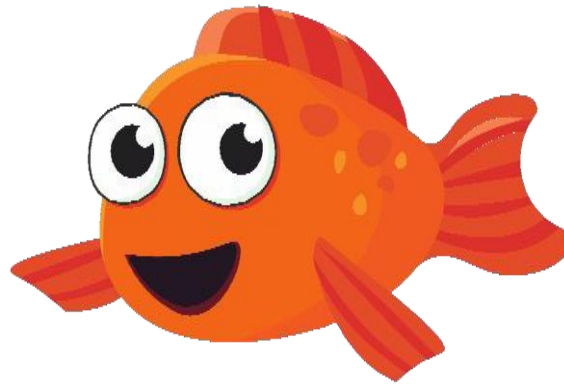
I threatened the user with an urgent message.

I added a link that looks like it goes to Wombank - but it really sends people to my site so I can steal their information and money!

- Send emails that look like a phishing attack
- If the recipient falls for it, the intervention warns them and highlights the cues to look for, in a short, engaging format
- User studies show the embedded training is effective
- Delivering the same training by direct email is not effective

Anti-Phishing Phil

- An online game that teaches people to recognize phishing URLs.



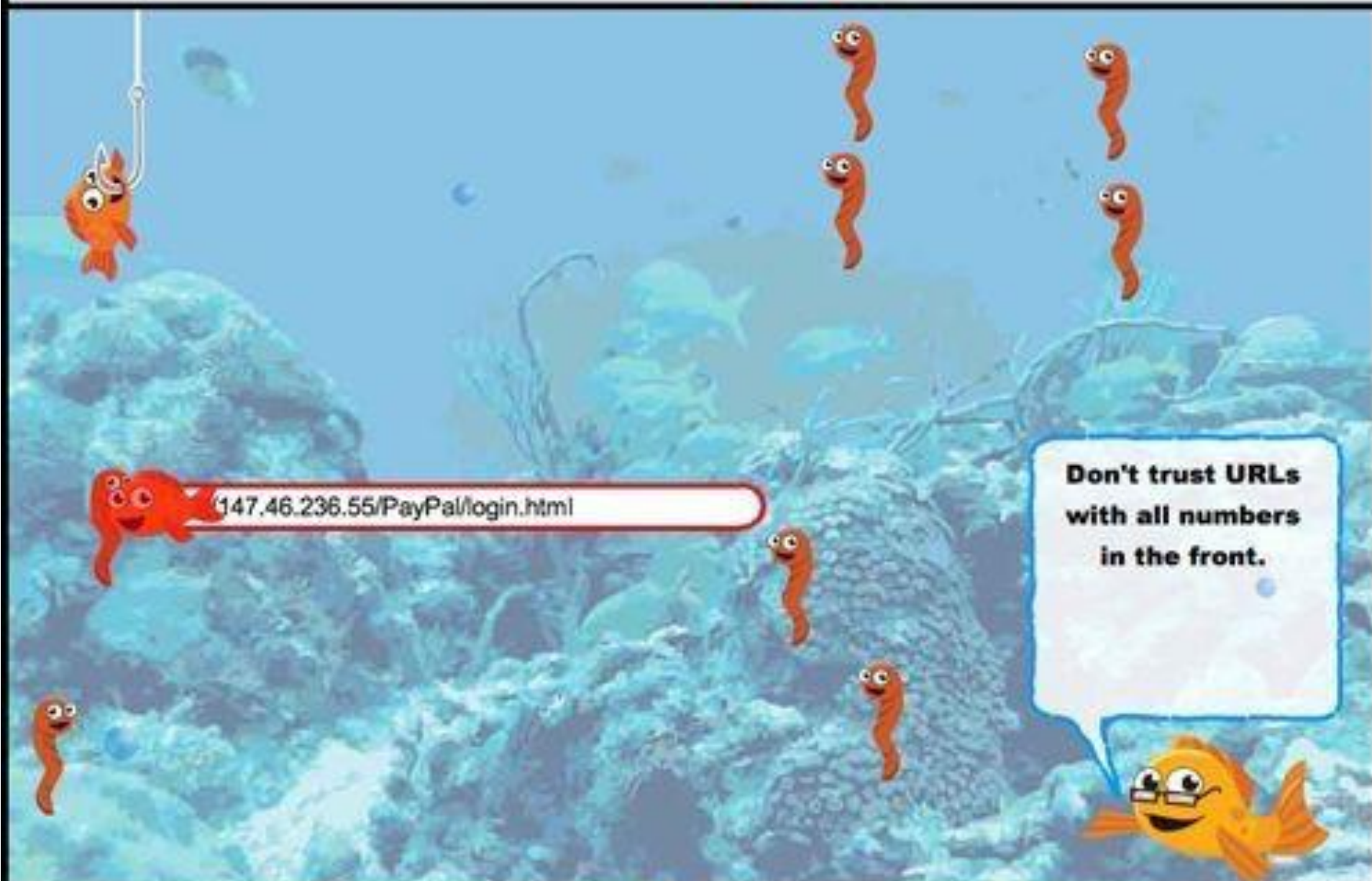
[Anti-Phishing Phil: the design and evaluation of a game that teaches people not to fall for phish](#), Sheng et al., SOUPS 2007

ROUND 1

SCORE: 0

LIVES: 

TIME LEFT: 1 : 44



WITH URL REVEALED:

E

EAT LEGITIMATE URLS

R

REJECT PHISHING URLS

T

ASK YOUR FATHER FOR HELP

Congratulations! You May Proceed to the Next Round

(✓) correct choice (✗) incorrect choice



<http://165.246.121.80/wamu/>

SCAM ALERT! URLs with all numbers in the front are usually scam.



<http://www.msn-verify.com/>

SCAM ALERT! keywords such as verify, update in the domain usually means it is scam.



<http://www.chase.com>

Chase.com is part of the J.P. Chase Corporation.



<https://www3.nationalgeographic.com/>

Don't be fooled by the www3, this site belongs to nationalgeographic.com



<http://www.onlineregionsbank.com/>

SCAM ALERT! Regions bank website is regions.com, not onlineregionsbank.com



<http://www.citizensbank.com>

citizensbank.com belongs to Citizens Bank.



<http://147.91.75.1/ebay/>

SCAM ALERT! URLs with all numbers in the front are usually scam.



<http://www.amazon.com>

amazon.com is the shopping site Amazon.

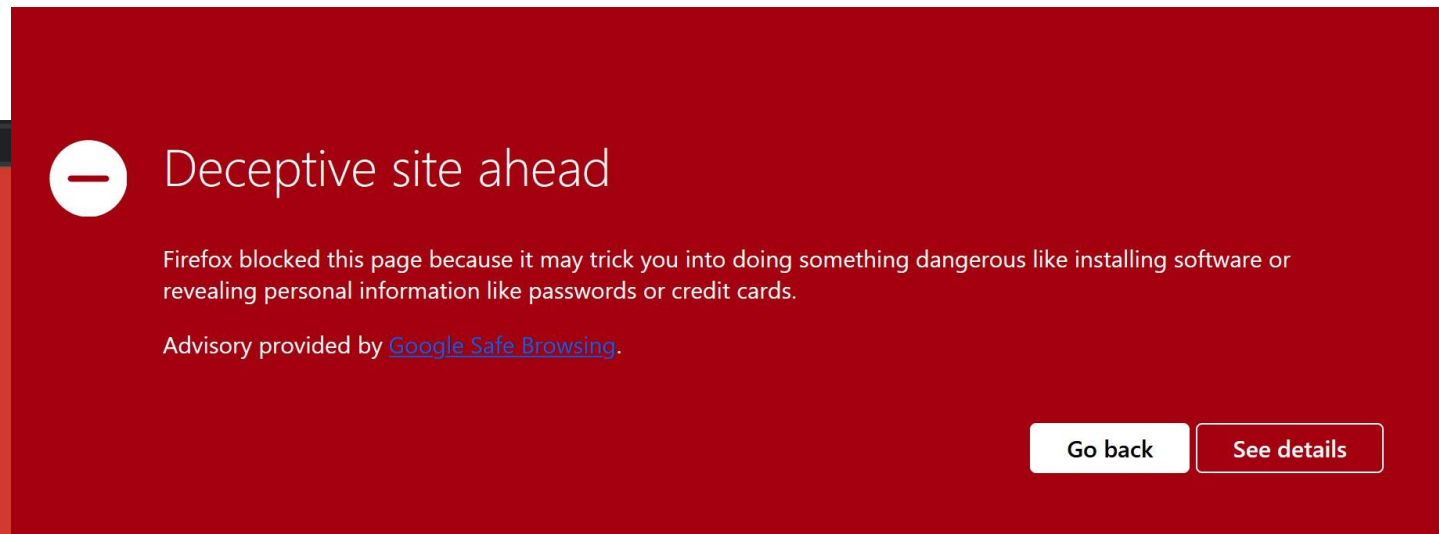
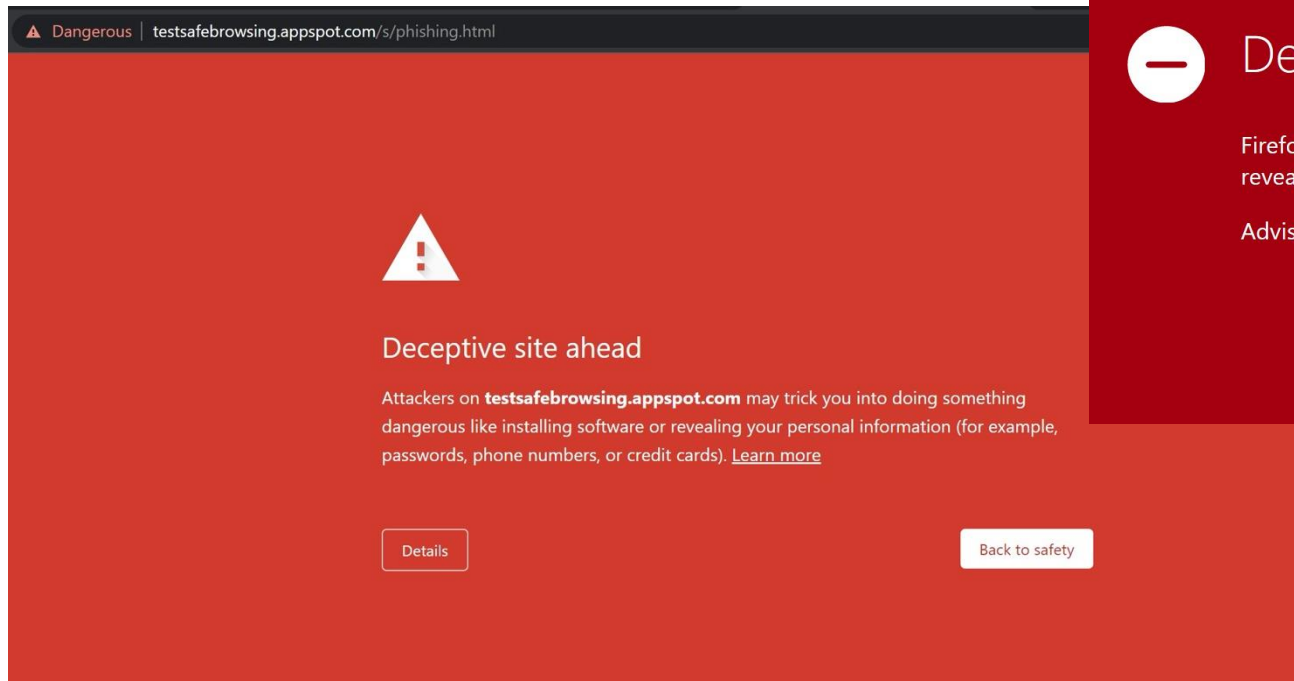
Study results

- User study:
 - Participants were asked to identify fraudulent websites before and after taking one of three phishing trainings (15 min each):
 - Anti-Phishing Phil
 - Reading an anti-phishing tutorial created based on the game
 - Reading existing online training materials
 - Game led to better identifying phishing sites



Modern Anti-Phishing

- Largely driven by [Google Safe Browsing](#)
 - Browser sends 32-bit prefix of hash(url)
 - API says: good or bad



Demo 1: Safari path supression

Demo 2: Unicode in the URL bar

- What if we navigate to facebook.com?

Phishing in the age of generative AI

- Generative AI lowers the cost of phishing attacks
 - One [study](#) compared LLMs' ability v. human experts to conduct spear phishing attacks
 - Click through rates for human-generated (54%) and LLM-generated (56%) were similar
 - Using LLMs can increase profitability up to 50%
- Also enables increased sophistication of attacks
 - Deepfakes used in social engineering attacks

Discussion

Warm up: ask a student to share a question from their reflections

Next time:

- (Not optional) Sign up for a time to meet with me next week to discuss your project proposals
- (Optional) fill out course feedback form
- Security warnings next week:
 - Jedsada leading discussion on Monday
 - Salah leading discussion on Wednesday